BREAKER - Fiche de défense

Secure Horizons • 11 octobre 2026 • Romain et Timéo
Track 1 / Fintech Security / axe 4 : incidents DeFi

Menace et scénario démontré

Des signataires trompés approuvent plusieurs paiements vers un nouveau bénéficiaire. Sur notre portefeuille Avalanche Fuji : 280 500 mUSD tentés, 0 sorti dans la démo documentée. Jetons fictifs, aucune attaque sur un tiers. Un paiement habituel reste exécutable.

Détection et réponse - le client garde le dernier recours

Règles sur l'historique + Isolation Forest ; simulation du transfert ERC-20 par eth_call ; agent Bedrock ; oracle Web avec citations vérifiées et sources croisées. Le LLM ne peut pas abaisser le risque imposé par les règles. Explication simple : faits, risque et action à entreprendre.

Protection : signature supplémentaire ou attente. **Cosignataire :** signature automatique ou refus ; dérogation humaine renforcée après délai, sans veto définitif. Dans la démo : 2/5 normalement, 3/5 si risque. Annuler les paiements frauduleux, révoquer une clé volée, puis rétablir après vérification indépendante. Sous contrainte : annuler la proposition concernée et en créer une nouvelle ; l'unanimité ne la débloque pas.

Mesures reproductibles - corpus synthétique

Jeu final : 274 paiements	Résultat
Fraudes freinées ou mises en attente	38 / 40 = 95 %
Fraudes mises en attente (hold)	31 / 40 = 77,5 %
Montants frauduleux en attente	1,119 M / 1,231 M mUSD = 90,9 %
Paiements normaux en attente à tort	12 / 234 = 5,1 %
Oracle Web - test historique	35 adresses ; précision / rappel 100 %
Latence historique proposition -> on-chain	≤ 1 s local ; 5-6 s Fuji (pas un SLA)

Protocole : modèle appris sur train seulement ; final préparé par l'autre membre de l'équipe après corrections du holdout. Rejeu final sans changer les seuils. Freiner ≠ empêcher un vol. Temps de réponse humain non mesuré ; latence Web/LLM distincte.

Référentiels et auditabilité

NIST CSF 2.0 : Detect (analyse), Respond (confinement / preuves), Recover (reprise), Protect (quorum / clés). **ATT&CK T1078 :** rapprochement avec l'usage abusif d'identités valides ; adaptation Web3. **ATLAS AML.T0051 :** injection de prompt dans pages et libellés. Traces JSONL, hashes de transactions, raisons et rapport d'incident ; playbook et annexe conformité dans le dépôt.

Limites et prochaine étape

Contrat non audité indépendamment : tests / analyse statique ne garantissent pas l'absence de pertes. Données synthétiques ; pas de preuve client. Simulation partielle ; oracle et réseau peuvent échouer. Dashboard / relais réservés à la démo locale. Le contrat de test détient les mUSD ; futur Guard Safe à développer et auditer. Qualification hors garde et conformité réglementaire à valider, aucune certification revendiquée. Prochaine étape : audit externe et pilotes sur données publiques ou autorisées.

Preuves : shared/mesures.md • shared/audit-contrat.md • shared/submit/playbook.md
Dépôt : github.com/veryromain/hackathon-ia-cyber (accès jury requis)
Références : attack.mitre.org/techniques/T1078/ • atlas.mitre.org/techniques/AML.T0051 • NIST CSF 2.0, publication 957258